
PANDUAN UNTUK DEVELOPER APLIKASI EKSTERNAL

Integrasi Login SSO UNPAM

Alur redirect browser dan verifikasi JWT melalui API SSO

Redirect-based SSO

JWT verification

API response schema

Tujuan: membantu tim aplikasi menghubungkan login lokal ke SSO UNPAM.

Untuk: developer backend/web aplikasi yang menerima callback SSO.

Versi dokumen: 1.0 · 5 Oktober 2026

Kontrak utama: GET `/api/b2b/token-verify`

Dokumen teknis berdasarkan kontrak API dan dokumentasi integrasi SSO yang tersedia saat penyusunan. Endpoint dan domain final untuk setiap aplikasi perlu dikonfirmasi kepada tim SSO.

1. Ringkasan integrasi

Aplikasi eksternal tidak mengelola password SSO dan tidak memverifikasi JWT sendiri. Browser pengguna diarahkan ke halaman login SSO; setelah autentikasi, SSO mengirim JWT ke callback aplikasi. Backend aplikasi kemudian meminta API SSO memverifikasi token dan mengembalikan profil yang sesuai.

Jenis protokol. Kontrak yang didokumentasikan saat ini adalah integrasi khusus UNPAM berbasis *redirect + JWT verification*. Jangan mengasumsikan adanya `client_id`, `client_secret`, discovery document, authorization-code exchange, atau ID Token OIDC. Istilah yang tepat untuk panduan ini adalah “Integrasi SSO UNPAM berbasis redirect dan verifikasi JWT”.

- 1 Mulai login.** Aplikasi mengarahkan browser ke `/login?domain=<domain-terdaftar>`.
- 2 Autentikasi di SSO.** Pengguna menyelesaikan proses login pada domain SSO.
- 3 Callback.** SSO mengarahkan browser ke callback aplikasi, misalnya `/api/loginssso?token=<JWT>`.
- 4 Verifikasi server-ke-server.** Backend aplikasi mengirim token ke `GET /api/b2b/token-verify?token=...`
- 5 Buat sesi aplikasi.** Jika respons `200`, aplikasi membuat sesi lokalnya sendiri dan mengalihkan pengguna ke URL bersih tanpa token.

Yang perlu didaftarkan

- Domain utama aplikasi dan alternate domain yang akan digunakan.
- Path callback yang menangani parameter `token` (contoh pada panduan yang ada: `/api/loginssso`).
- Lingkungan SSO yang dipakai (development atau production).
- Kontak teknis aplikasi untuk uji callback dan pemetaan data pengguna.

Path callback mengikuti nilai `ssolink` yang didaftarkan pada konfigurasi aplikasi di SSO. Jangan menerima callback atau domain tujuan bebas dari parameter yang dikirim pengguna.

2. URL dan cara memulai login

Gunakan base URL yang ditetapkan tim SSO untuk aplikasi dan lingkungan Anda. Dokumen yang tersedia mencantumkan host berikut:

Lingkungan	Base URL yang tercantum	Catatan
Production	<code>https://satu.unpam.ac.id</code>	Base URL utama pada panduan verifikasi token.
Production alternatif	<code>https://satu.sasmitagroup.org</code>	Juga tercantum pada panduan token B2B; gunakan hanya jika ditetapkan untuk integrasi Anda.
Development	<code>https://devsso.unpam.ac.id</code>	Tercantum pada dokumentasi paket tombol login. Konfirmasikan akses/test data sebelum uji.

Konfirmasi sebelum go-live. Sumber repo memuat lebih dari satu host production serta host development. Minta tim SSO memastikan base URL yang benar untuk aplikasi, domain callback, dan environment; jangan menebak berdasarkan nama host.

Redirect langsung

Domain dikirim tanpa skema `https://`. Buat URL menggunakan URL builder agar parameter ter-encode dengan benar.

```
const ssoLogin = new URL("/login", SSO_BASE_URL);
ssoLogin.searchParams.set("domain", "app.example.ac.id");
window.location.assign(ssoLogin.toString());
```

Contoh hasil:

```
https://satu.unpam.ac.id/login?domain=app.example.ac.id
```

Tombol login (opsional)

Repo frontend menyediakan paket tombol iframe `@lpti/unpam-sso`. Paket ini membantu menampilkan tombol dan memulai login; paket tersebut **tidak menggantikan** callback backend atau pemanggilan `token-verify`.

```
npm install @lpti/unpam-sso

import { embedButtonLogin } from "@lpti/unpam-sso";
embedButtonLogin("login-container", { env: "prod", lang: "id" });
```

Paket mendeteksi domain halaman untuk mengisi parameter `domain`. Pastikan domain aplikasi sudah terdaftar di SSO sebelum menggunakan tombol.

3. Callback dan verifikasi token

Callback aplikasi

Setelah autentikasi, SSO mengirim browser ke callback yang didaftarkan. Contoh path integrasi:

```
https://app.example.ac.id/api/loginso?token=<JWT_USER_INFO>
```

Ambil token dari query pada handler callback backend. Jangan menganggap isi JWT yang belum diverifikasi sebagai identitas terpercaya.

Endpoint verifikasi

Properti	Nilai	Keterangan
Method	GET	Permintaan dari backend aplikasi ke API SSO.
Path	/api/b2b/token-verify	Endpoint memverifikasi signature dan masa berlaku JWT.
Query	token (string, wajib)	JWT yang diterima pada callback.
Autentikasi endpoint	Tidak perlu bearer token/cookie SSO	Endpoint menerima JWT callback sebagai input verifikasi.
Sukses	200 OK	JSON TokenDetailB2BResponseDto.
Token tidak valid	401 Unauthorized	Signature/masa berlaku/claim tidak valid atau profil sumber tidak tersedia.

Contoh request

```
curl --get --data-urlencode "token=$USER_INFO_JWT" "${SSO_BASE_URL}/api/b2b/token-verify"
```

Panggil endpoint dari server aplikasi. Jangan menaruh token pada kode frontend, local storage, atau log. Token berada di query string sehingga access log dan sistem observability perlu menyamakan parameter token.

Contoh handler Node.js/Express

```
// Ilustrasi: sesuaikan dengan session middleware aplikasi.
app.get("/api/loginso", async (req, res) => {
  res.set("Referrer-Policy", "no-referrer");
  const token = req.query.token;
  if (typeof token !== "string" || !token) {
    return res.status(400).send("Callback SSO tidak lengkap");
  }

  try {
    const verifyUrl = new URL("/api/b2b/token-verify", SSO_BASE_URL);
    verifyUrl.searchParams.set("token", token);
    const result = await fetch(verifyUrl, {
      headers: { Accept: "application/json" }
    });

    if (result.status === 401) {
      return res.redirect(303, "/login?error=sso");
    }
    if (!result.ok) {
      return res.status(502).send("Verifikasi SSO sementara gagal");
    }
  }
});
```

```
const identity = await result.json();
req.session.user = mapMinimumUser(identity);
return res.redirect(303, "/dashboard");
} catch {
return res.status(502).send("Verifikasi SSO sementara gagal");
}
});
```

Fungsi `mapMinimumUser` adalah logika aplikasi sendiri: petakan hanya identitas dan atribut yang dibutuhkan. Jangan menyimpan JWT SSO sebagai sesi jangka panjang; buat sesi lokal aplikasi dengan cookie yang aman.

4. Kontrak response token-verify

Respons sukses bertipe `TokenDetailB2BResponseDto`. Nama properti bersifat case-sensitive. Aplikasi harus siap menerima nilai nullable sebagaimana ditandai di bawah.

Field	Tipe	Null/opsional	Makna
username	string	Tidak	Username SSO; kunci identitas yang dipakai untuk lookup sumber.
nik_pegawai	string null	Nullable	NIK/ID pegawai bila tersedia; dapat <code>null</code> .
source	"HRMS" "MAHASISWA"	Tidak	Sumber data identitas saat ini.
hrms	HRMSPenugasanDto null	Nullable	Profil dan daftar penugasan HRMS; bernilai <code>null</code> untuk sumber mahasiswa.
mahasiswa	MahasiswaSiaDto null	Nullable	Profil mahasiswa; bernilai <code>null</code> untuk sumber HRMS.
sandbox	boolean	Opsional	Bernilai <code>true</code> pada token sandbox; umumnya tidak dikirim pada login normal.

Interpretasi sumber. Untuk `source`: "HRMS", gunakan objek `hrms` dan periksa bahwa `mahasiswa` dapat bernilai `null`. Untuk `source`: "MAHASISWA", gunakan objek `mahasiswa` dan periksa bahwa `hrms` dapat bernilai `null`. Jangan mengasumsikan semua field profil terisi.

Contoh sukses — pengguna HRMS

```
{
  "username": "pegawai-demo",
  "nik_pegawai": "198012340001",
  "source": "HRMS",
  "hrms": {
    "id_pegawai": "pegawai-demo",
    "nama": "Pengguna Contoh",
    "email": "pegawai@example.ac.id",
    "no_hp": null,
    "status_aktif": 1,
    "penugasan": [
      {
        "id_institusi": 1,
        "nama_institusi": "Universitas Contoh",
        "nik_pegawai": "198012340001",
        "nama_pekerjaan": "DOSEN",
        "homebase": true,
        "jabatan": "Anggota",
        "tipe_lembaga": "AKADEMIK",
        "kd_lembaga": "FAK",
        "nama_lembaga": "Fakultas Contoh",
        "kd_sub_lembaga": null,
        "nama_sub_lembaga": null,
        "status_aktif": 1
      }
    ]
  },
  "mahasiswa": null
}
```

Semua identitas pada contoh bersifat fiktif. Nilai `nik_pegawai` dapat `null`. Array `penugasan` dapat kosong.

5. Schema detail HRMS

HRMSPenugasanDto

Field	Tipe	Null	Makna
id_pegawai	string	Tidak	ID pegawai HRMS.
nama	string	Tidak	Nama pegawai.
email	string null	Nullable	Email pegawai.
no_hp	string null	Nullable	Nomor handphone.
status_aktif	number null	Nullable	Status aktif dari HRMS.
penugasan	HRMSPenugasanDetailDto[]	Tidak	Daftar penugasan; array dapat kosong.

HRMSPenugasanDetailDto

Field	Tipe	Null	Makna
id_institusi	number	Tidak	ID institusi.
nama_institusi	string	Tidak	Nama institusi.
nik_pegawai	string null	Nullable	NIK pada penugasan.
nama_pekerjaan	"DOSEN" "GURU" "STAF" "KARYAWAN" "STRUKTURAL" "TENDIK" "LAINYA" null	Nullable	Jenis pekerjaan.
homebase	boolean	Tidak	Penugasan homebase atau bukan.
jabatan	"Ketua" "Wakil Ketua" "Sekretaris" "Anggota" "Dekan" "Direktur" "Rektor" null	Nullable	Jabatan pada penugasan.
tipe_lembaga	"AKADEMIK" "LEMBAGA" null	Nullable	Jenis lembaga.
kd_lembaga	string null	Nullable	Kode lembaga.
nama_lembaga	string null	Nullable	Nama lembaga.
kd_sub_lembaga	string null	Nullable	Kode sublembaga.
nama_sub_lembaga	string null	Nullable	Nama sublembaga.
status_aktif	number null	Nullable	Status aktif penugasan.

Enum nilai string di atas ditulis sesuai DTO API saat dokumen ini dibuat. Perlakukan enum sebagai kontrak dan konfirmasikan perubahan melalui tim SSO.

6. Schema detail mahasiswa

MahasiswaSiaDto memakai kapitalisasi field persis seperti di bawah. Dua field pertama wajib dan tidak nullable; field lain bertipe `string | null`.

Field persis	Tipe	Null	Makna
Nim	string	Tidak	Nomor induk mahasiswa.
Nama	string	Tidak	Nama mahasiswa.
Kelas	string null	Nullable	Kelas mahasiswa.
Alamat	string null	Nullable	Alamat.
Tanggal_lahir	string null	Nullable	Tanggal lahir.
Jenis_kelamin	string null	Nullable	Jenis kelamin.
Telepon	string null	Nullable	Nomor telepon.
Agama	string null	Nullable	Agama.
Tempat_lahir	string null	Nullable	Tempat lahir.
Tahun_masuk	string null	Nullable	Tahun masuk.
Propinsi	string null	Nullable	Provinsi.
Kabupaten	string null	Nullable	Kabupaten.
Kecamatan	string null	Nullable	Kecamatan.
Universitas	string null	Nullable	Universitas.
Fakultas	string null	Nullable	Fakultas.
Kode_program_studi	string null	Nullable	Kode program studi.
Program_studi	string null	Nullable	Nama program studi.
Kode_pos	string null	Nullable	Kode pos.
Kewarganegaraan	string null	Nullable	Kewarganegaraan.
Email	string null	Nullable	Email mahasiswa.
Nomor_identitas	string null	Nullable	Nomor identitas.
Nomor_telepon	string null	Nullable	Nomor telepon.
Nomor_handphone	string null	Nullable	Nomor handphone.
Pekerjaan	string null	Nullable	Pekerjaan.
Foto	string null	Nullable	Referensi atau URL foto.
Waktu_perkuliahan	string null	Nullable	Waktu perkuliahan.
Peminatan	string null	Nullable	Peminatan.
Nama_ibu_kandung	string null	Nullable	Nama ibu kandung.
Nama_orangtua	string null	Nullable	Nama orang tua.
Alamat_orangtua	string null	Nullable	Alamat orang tua.

Field persis	Tipe	Null	Makna
Nomor_telepon_orangtua	string null	Nullable	Nomor telepon orang tua.
Nomor_hp_orangtua	string null	Nullable	Nomor handphone orang tua.
Pekerjaan_orangtua	string null	Nullable	Pekerjaan orang tua.
Status_mahasiswa	string null	Nullable	Status mahasiswa.
Semester	string null	Nullable	Semester.

Data mahasiswa dapat mencakup data pribadi dan keluarga. Simpan hanya atribut yang memang dibutuhkan, batasi akses internal, dan tetapkan retensi sesuai kebijakan aplikasi.

7. Contoh response dan penanganan error

Contoh sukses — mahasiswa

```
{
  "username": "20260001",
  "nik_pegawai": null,
  "source": "MAHASISWA",
  "hrms": null,
  "mahasiswa": {
    "Nim": "20260001",
    "Nama": "Mahasiswa Contoh",
    "Kelas": "01A",
    "Alamat": null,
    "Tanggal_lahir": null,
    "Jenis_kelamin": null,
    "Telepon": null,
    "Agama": null,
    "Tempat_lahir": null,
    "Tahun_masuk": "2026",
    "Propinsi": null,
    "Kabupaten": null,
    "Kecamatan": null,
    "Universitas": "Universitas Contoh",
    "Fakultas": null,
    "Kode_program_studi": null,
    "Program_studi": "Program Contoh",
    "Kode_pos": null,
    "Kewarganegaraan": null,
    "Email": null,
    "Nomor_identitas": null,
    "Nomor_telepon": null,
    "Nomor_handphone": null,
    "Pekerjaan": null,
    "Foto": null,
    "Waktu_perkuliahan": null,
    "Peminatan": null,
    "Nama_ibu_kandung": null,
    "Nama_orangtua": null,
    "Alamat_orangtua": null,
    "Nomor_telepon_orangtua": null,
    "Nomor_hp_orangtua": null,
    "Pekerjaan_orangtua": null,
    "Status_mahasiswa": null,
    "Semester": null
  }
}
```

Contoh hanya untuk ilustrasi bentuk JSON; nilai data bukan data pengguna sebenarnya.

Status yang perlu ditangani

Status	Kondisi umum	Respons aplikasi yang disarankan
200 OK	JWT valid dan profil sumber ditemukan.	Buat sesi lokal, buang token dari URL, lanjutkan ke halaman tujuan.
401 Unauthorized	JWT tidak valid/kedaluwarsa, claim tidak sesuai, atau detail HRMS/SIA tidak tersedia.	Jangan membuat sesi; minta pengguna memulai login SSO kembali dengan pesan umum.
Timeout / 5xx	SSO atau layanan profil sedang tidak tersedia.	Tampilkan gangguan sementara; jangan menganggap token valid dan jangan mengulang tanpa batas.

Status	Kondisi umum	Respons aplikasi yang disarankan
400 pada callback aplikasi	Parameter token tidak ada atau bukan string yang diharapkan.	Tolak callback dan arahkan pengguna memulai login ulang.

Jangan fallback ke decode JWT lokal. Jika endpoint verifikasi tidak bisa dijangkau, jangan menerima payload hasil decode sebagai login sukses. Validitas signature dan masa berlaku harus dipastikan oleh API SSO.

8. Sandbox (opsional untuk pengujian)

Mode sandbox adalah alur terpisah dan hanya dipakai untuk aplikasi yang telah diaktifkan serta diberi kredensial sandbox oleh administrator SSO. Jangan gunakan alias/kode sandbox sebagai kredensial production.

1. Aplikasi mengirim `POST /api/sandbox/login` dengan `username` alias, `password` kode akses sandbox, dan `domain` terdaftar.
2. Respons sukses berisi `confirmation_token` yang berlaku 300 detik. Minta persetujuan pengguna sebelum melanjutkan; jangan tampilkan token.
3. Kirim `POST /api/sandbox/confirm` dengan `domain` dan `confirmation_token`.
4. SSO mengonsumsi token konfirmasi satu kali lalu mengirim `HTTP 302` ke callback aplikasi dengan JWT sandbox.
5. Backend aplikasi tetap memverifikasi JWT melalui `/api/b2b/token-verify`. Response sandbox menambahkan `"sandbox": true`; JWT sandbox berlaku 15 menit dan memiliki audience untuk aplikasi.

```
POST /api/sandbox/login
{
  "username": "qa-alias",
  "password": "kode-akses-sandbox",
  "domain": "app.example.ac.id"
}

POST /api/sandbox/confirm
{
  "domain": "app.example.ac.id",
  "confirmation_token": "<token-sementara>"
}
```

Kredensial sandbox, confirmation token, dan JWT sandbox adalah rahasia. Jangan masukkan ke log, analytics, URL buatan aplikasi, atau dokumentasi yang berisi nilai nyata. Tampilkan penanda **SANDBOX / DEVELOPMENT** pada aplikasi bila sesi sandbox diterima.

9. Checklist sebelum go-live

- Domain dan callback HTTPS sudah didaftarkan dan cocok dengan konfigurasi SSO.
- Base URL production dan development sudah dikonfirmasi untuk aplikasi.
- Login langsung masuk ke SSO; aplikasi tidak meminta password SSO.
- Callback mengambil token di backend dan memanggil `token-verify` melalui HTTPS.
- Hanya respons `200` terverifikasi yang membuat sesi lokal.
- `401`, timeout, dan `5xx` tidak menghasilkan sesi dan ditangani dengan aman.
- Token query disamarkan dari log, tidak disimpan di browser, dan segera dihapus dari URL.
- Cookie sesi lokal memiliki atribut keamanan sesuai arsitektur aplikasi.
- Aplikasi hanya menyimpan field profil minimum yang dibutuhkan.
- Uji HRMS dan mahasiswa dilakukan; field nullable dan array kosong ditangani.

Referensi kontrak

- `sso-api/docs/token-verify.md` — alur callback, endpoint verifikasi, dan skema response.
- `sso-api/src/modules/auth-b2b/auth-b2b.dto.ts` — DTO response dan field berserta tipe/nullability.
- `sso-api/src/modules/auth-b2b/token-info.controller.ts` — perilaku validasi token dan pemanggilan sumber data.
- `sso-api/docs/frontend/sandbox-login-frontend.md` dan modul sandbox API — alur sandbox opsional.
- `sso-frontend/npm-package/button-sso/README.md` — tombol login opsional.

Jika kontrak API berubah, perbarui panduan ini dari DTO/OpenAPI terbaru dan lakukan pengujian integrasi pada setiap base URL yang didukung.